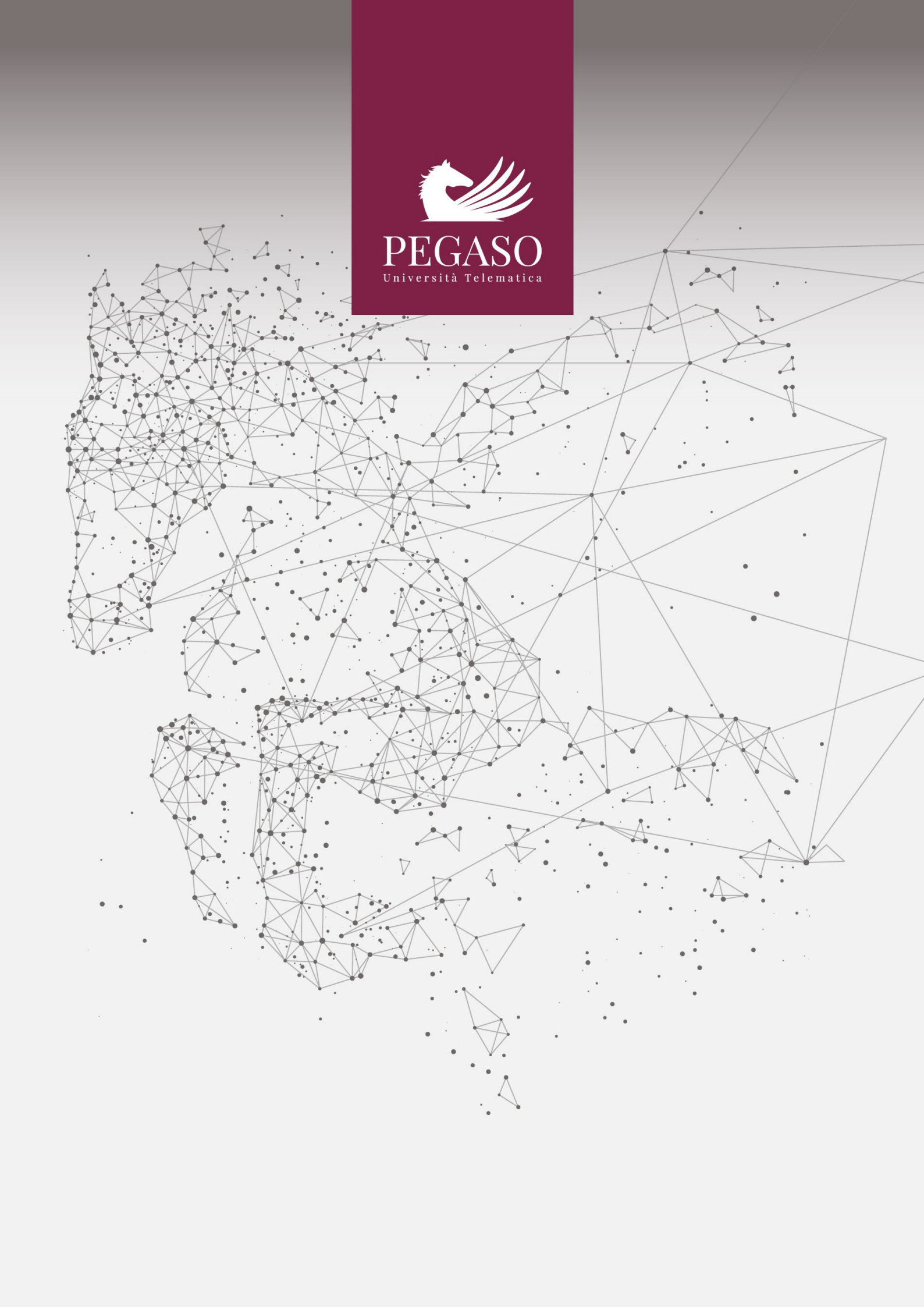

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Indice

1. HTTP ED HTTPS 3
2. CRITTOGRAFIA 6
3. SSL E TLS 10
BIBLIOGRAFIA E SITOGRAFIA 12

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

1. HTTP ed HTTPS

L'**HyperText Transfer Protocol** (**HTTP**) è un protocollo a livello applicativo usato come principale sistema per la trasmissione d'informazioni sul web ovvero in un'architettura tipica **Client-Server**. L'architettura su cui si innesta l'HTTP è di tipo **Client-Server**:

- il **client** invia una richiesta al server, specificando l'URL della risorsa che desidera recuperare;
- il **server** risponde con un messaggio di stato che indica se la richiesta è stata eseguita con successo o meno, e invia i dati richiesti al client.

Nell'uso comune il client corrisponde al browser ed il server la macchina su cui risiede il sito web. Vi sono quindi due tipi di messaggi HTTP: messaggi richiesta (detti **HTTP requests**) e messaggi risposta (detti **HTTP responses**).

Una transazione HTTP standard prevede, nell'ordine:

- Di instaurare una connessione TCP (client → server).
- Invio di un messaggio request (client → server).
- Invio di un messaggio response (client ← server).
- Chiusura della connessione http.

Il protocollo HTTP non prevede in modo intrinseco funzionalità per garantire la sicurezza e la riservatezza dei dati che vengono scambiati tra client e server.

Con l'evoluzione del web moderno, specialmente per l'e-commerce, è nata la necessità di rendere il protocollo sicuro per la gestione di transazioni bancarie, autenticazione, etc.

Chiunque connesso alla rete può potenzialmente leggere il traffico HTTP generato da due entità per rubare dati confidenziali o alterare in modo malevolo il contenuto (man-in-the-middle attack).

L'HTTP, dunque, si focalizza esclusivamente sulla trasmissione dei dati, e quindi informazioni, senza preoccuparsi del modo in cui queste viaggiano da un luogo a un altro. Per questo motivo, l'HTTP è anche chiamato "sistema senza stato", ciò significa che abilita la connessione esclusivamente su richiesta:

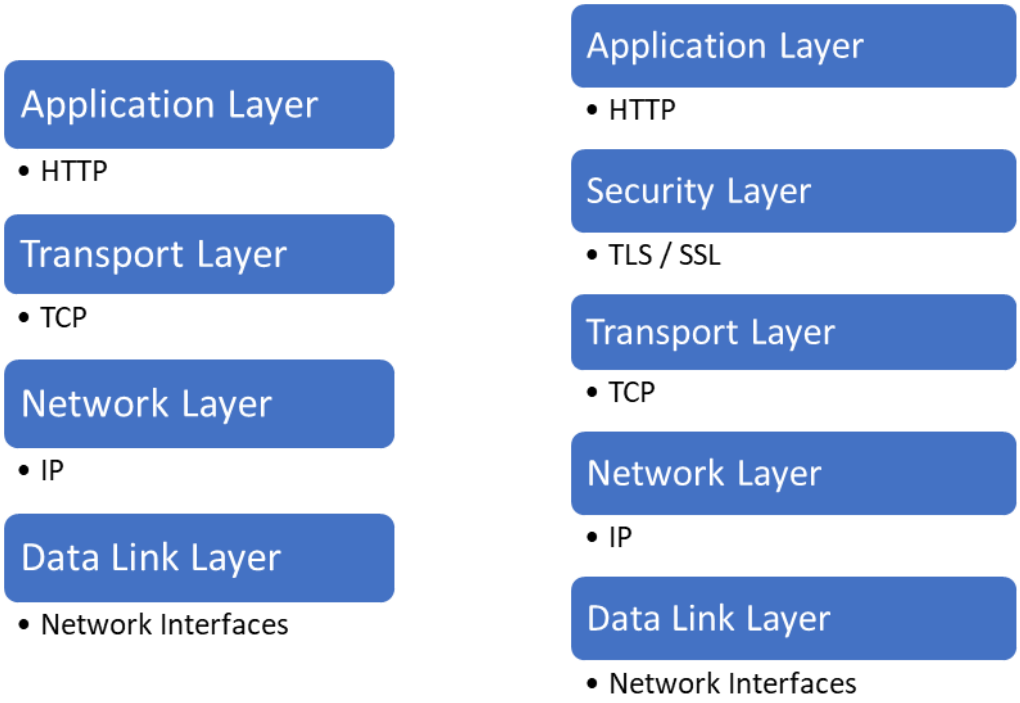
- l'utente, cliccando su un collegamento, invia una richiesta al Server;
- il Server che visualizza questa richiesta risponde aprendo la pagina.

Più veloce è la connessione, più velocemente verranno ricevute le informazioni richieste.

La sicurezza in ambito HTTP è realizzata inserendo uno strato intermedio tra HTTP e TCP, chiamato **SSL** (**Secure Socket Layer**) o **TLS** (**Transport Layer Security**).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).



Il protocollo **HTTPS** è di fatto un un'estensione dell'HTTP, dove quella "**S**" deriva dall'abbreviazione di "Secure" (esso, in definitiva, rappresenta un protocollo per la comunicazione sicura).

L'**HTTPS** (**HyperText Transfer Protocol over Secure Socket Layer**) non è dunque l'opposto dell'HTTP, anzi, sono molto simili tra di loro: entrambi si riferiscono allo stesso "protocollo di trasferimento ipertestuale", che consente di visualizzare attraverso il Browser Web i dati che vengono richiesti; tuttavia, l'HTTPS risulta essere leggermente diverso, più avanzato, più sicuro.

Il vantaggio di usare un layer aggiuntivo è che, una volta stabilita una connessione sicura, il protocollo HTTP resta inalterato.

Client e server non devono alterare la loro logica di processo per utilizzare HTTPS

HTTPS fornisce dunque:

- **Autenticazione del server**: un client può verificare in modo sicuro di essere connesso al server atteso e non ad un impostore.
- **Autenticazione del client**: il server può verificare l'identità di un certo client connesso indipendentemente dalle tecniche http di autenticazione.
- **Integrità della trasmissione**: è possibile rilevare se i dati scambiati fra client e server sono stati manomessi da un terzo agente.
- **Cifratura della trasmissione**: tutti i dati trasmessi sono leggibili soltanto dal rispettivo client e server; non è possibile spiare il traffico in transito, nemmeno se si opera su un canale non sicuro (ex. WiFi non protetto).

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

HTTPS è basato sulle seguenti tecniche di crittografia:

- Crittografia a chiave simmetrica.
- Crittografia a chiave asimmetrica.
- Firma digitale.
- Certificato digitale.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

2. Crittografia

La **crittografia** è la branca della crittologia che tratta delle "scritture nascoste", ovvero dei metodi per rendere un messaggio "offuscato" in modo da non essere comprensibile/intelligibile a persone non autorizzate a leggerlo.

I tipi di minacce (ed i conseguenti problemi) che si possono avere durante lo scambio di messaggi privati sono:

- **Intercettazione**: lettura del contenuto, perché trasmesso in chiaro o perché cifrato con un algoritmo noto → problema della confidenzialità.
- **Modifica**: intercettazione e modifica del contenuto → problema dell'integrità.
- **Invio di messaggio sotto falso nome**: si intercetta e si modifica il messaggio creandone uno il cui mittente si fa credere un altro, prendendone la potestà e le credenziali → problema dell'autenticazione.
- **Ripudio della potestà del messaggio**: quando si nega di aver spedito un messaggio, pur avendolo fatto → problema del non ripudio.

Vi sono 2 principali tecniche di crittografia:

- Crittografia simmetrica.
- Crittografia asimmetrica.

La **crittografia simmetrica** utilizza algoritmi di decodifica a chiave privata. Si tratta di algoritmi in cui la funzione di codifica e quella di decodifica usano la stessa chiave privata (o chiavi private diverse ma in diretta relazione tra loro).

Mittente e destinatario hanno necessità di conoscere e adoperare la stessa chiave, mantenendola rigorosamente segreta e utilizzando un canale di comunicazione sicuro; Il problema, in questo caso, non è legato tanto alla complessità della chiave e dell'algoritmo utilizzato, ma tanto alla funzionalità logistica; c'è, infatti, il problema della distribuzione delle chiavi.

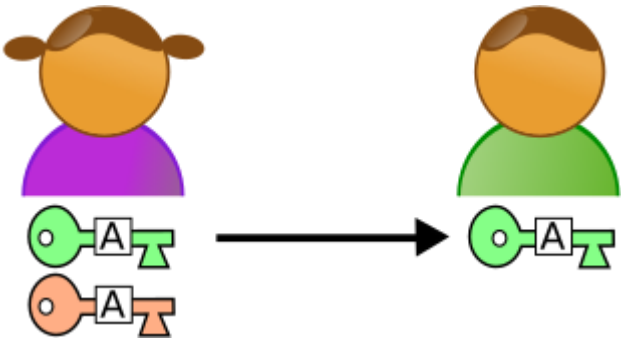
La **crittografia asimmetrica** usa due chiavi differenti:

- chiave di cifratura → chiave pubblica
- chiave di decifratura → chiave privata

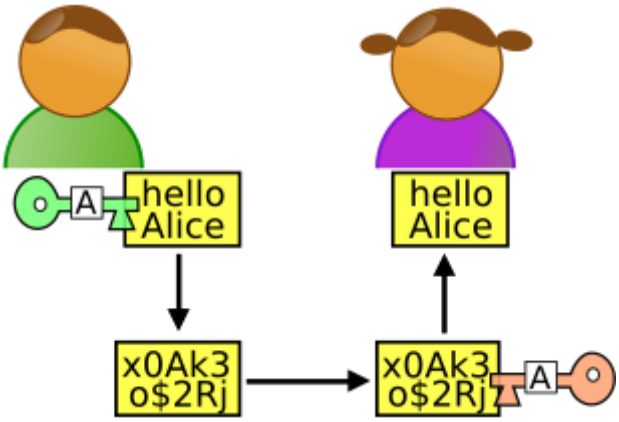
PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Immaginiamo che Alice e Bob debbano comunicare; se Bob deve inviare un messaggio ad Alice, i passi da compiere sono:



Alice possiede la chiave pubblica (verde) e privata (arancione); Alice consegna a Bob la chiave pubblica



Bob invia ad Alice il messaggio cifrato con la chiave pubblica di Alice e solo Alice può decodificarlo perché possiede la chiave privata di decifratura

Per segretare il messaggio c'è bisogno del lucchetto (la chiave) del destinatario mentre per ricevere viene usata esclusivamente la propria chiave segreta, rendendo l'intero processo di criptazione/decriptazione asimmetrico.

"*La crittografia asimmetrica potrebbe essere illustrata nel modo seguente: chiunque può chiudere un lucchetto facendo scattare l'anello metallico, ma solo chi ha la chiave può aprirlo. La chiusura è alla portata di tutti (come la cifratura) ma l'apertura è privata (come la decifrazione) e possibile solo per il possessore della chiave*".

Nonostante le due chiavi siano fra loro dipendenti, non è possibile risalire dall'una all'altra, pertanto anche si è a conoscenza di una delle due chiavi, non si può risalire all'altra; in questo modo è garantita l'integrità della crittografia.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

La **firma digitale** consente al sottoscrittore di rendere manifesta l'autenticità del documento informatico ed al destinatario di verificarne la provenienza e l'integrità. In sostanza i requisiti assolti sono: autenticità, integrità, non ripudio.

Per generare una firma digitale è necessario utilizzare una coppia di chiavi asimmetriche, attribuite in maniera univoca al titolare della coppia di chiavi:

- la prima, chiave privata, è destinata ad essere conosciuta solo dal titolare ed è utilizzata per la generazione della firma digitale da apporre al documento;
- la seconda, chiave da rendere pubblica, viene utilizzata per verificare l'autenticità della firma.

Caratteristica di tale metodo, detto crittografia a doppia chiave, è che, firmato il documento con la chiave privata, la firma può essere verificata con successo esclusivamente con la corrispondente chiave pubblica.

La sicurezza è garantita dalla impossibilità di ricostruire la chiave privata (segreta) a partire da quella pubblica, anche se le due chiavi sono univocamente collegate.

Supponiamo ora che Mario Rossi voglia inviare/ricevere un messaggio cifrato oppure voglia firmare digitalmente un documento. Mario Rossi deve divulgare la sua chiave pubblica agli altri attori della comunicazione: ogni persona che la possiede può inviare o ricevere da lui messaggi sicuri tramite cifratura asimmetrica con quella chiave pubblica oppure ricevere da lui documenti firmati con la chiave privata per poi verificare la firma con la suddetta chiave pubblica.

Tuttavia, qualsiasi individuo potrebbe divulgare una differente chiave pubblica (di cui conosce la relativa chiave privata) e dichiarare che è la chiave pubblica di Mario Rossi. Per evitare questo problema, Mario Rossi inserisce allora la sua chiave pubblica in un **certificato digitale** firmato da una terza parte fidata ("**trusted third party**"): tutti quelli che riconoscono questa terza parte devono semplicemente controllarne la firma per decidere se la chiave pubblica appartiene veramente a Mario Rossi.

Nella crittografia asimmetrica un certificato digitale è dunque un documento elettronico che attesta l'associazione univoca tra una chiave pubblica e l'identità di un soggetto (una persona, una società, un computer, etc) che dichiara di utilizzarla nell'ambito delle procedure di cifratura asimmetrica e/o autenticazione tramite firma digitale.

Tale certificato, fornito da un ente terzo fidato e riconosciuto come **Certification Authority** (**CA**), è a sua volta autenticato per evitarne la falsificazione sempre attraverso firma digitale ovvero cifrato con la chiave privata dell'associazione la quale fornisce poi la rispettiva chiave pubblica associata per verificarlo.

Nell'accesso ai siti web via HTTPS, attraverso i certificati possiamo accertarci che il server a cui ci si è connessi è autentico, ovvero è effettivamente quello che dichiara di essere. Il protocollo SSL prevede che, alla connessione, il server fornisca il proprio certificato digitale: se il certificato digitale è firmato da una CA

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

da noi riconosciuta, e la decifratura della firma del certificato ha buon fine, allora possiamo utilizzare la chiave pubblica presente nello stesso per avviare una comunicazione sicura.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

3. SSL e TLS

Il security layer è dunque implementato mediante **Secure Sockets Layer** (**SSL**) o **Transport Layer Security** (**TLS**); entrambi sono dei protocolli di sicurezza che garantiscono la protezione di una connessione Internet, proteggendo tutti i dati sensibili che vengono scambiati tra il client e il server, evitando dunque che qualche malintenzionato possa accedervi. In aggiunta, oltre a crittografare i dati trasmessi tra il Server e il Browser, la TLS autentica e verifica che il server a cui si sta effettuando la connessione sia sicuro, proteggendo i dati da qualunque manomissione.

ATTENZIONE: SSL e TLS sono protocolli simili ma non compatibili; SSL è stato sostituito da TLS, ma alcune volte ancora si utilizza l'acronimo SSL per indicare la crittografia HTTPS.

SSL (Secure Sockets Layer) e **TLS** (Transport Layer Security), funzionano creando una connessione criptata tra il browser e il server web utilizzando un **certificato digitale**.

Di seguito i passi che caratterizzano la comunicazione:

1. il processo inizia quando il browser invia una richiesta di connessione al server;
2. il server risponde inviando il proprio certificato digitale, che include una chiave pubblica;
3. il browser verifica la validità del certificato utilizzando un'autorità di certificazione (CA);
4. se il certificato è valido:
    a. il browser crea una chiave simmetrica segreta, la crittografa utilizzando la chiave pubblica del server e invia la chiave al server;
    b. il server decrittografa la chiave utilizzando la propria chiave privata e le due parti ora hanno una chiave condivisa per la comunicazione criptata;
    c. da quel momento in poi, tutte le informazioni scambiate tra il browser e il server sono criptate utilizzando la chiave simmetrica condivisa e decifrabili solo dal browser e dal server. Ciò garantisce che le informazioni vengano trasmesse in modo sicuro e protette da eventuali tentativi di intercettazione da parte di terzi se il certificato non è valido la connessione è interrotta.

SSL e TLS sono protocolli simili ma non compatibili, SSL è stato sostituito da TLS, ma alcune volte ancora si utilizza l'acronimo SSL per indicare la crittografia HTTPS.

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Di seguito una tabella comparativa schematica tra HTTP ed HTTPS:

HTTP	HTTPS
Si stabilisce una connessione TCP sulla porta 80	Si stabilisce una connessione TCP sulla porta 443 Si effettua l'handshake dei parametri di sicurezza
Request e response sono inviate e ricevute sul canale TCP	Request e response sono inviate e ricevute in modo cifrato attraverso TCP
La connessione TCP viene chiusa	La connessione SSL/TLS viene chiusa La connessione TCP viene chiusa

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).

Bibliografia e sitografia

- V. Roberto, M. Frailis, A. Gugliotta, P. Omero. Introduzione alle Tecnologie Web, McGraw-Hill, 2010
- A. S. Tanembaum. Computer Networks (4 ed.). Prentice Hall (4 ed.), 2003.
- F. Bergamasco - WEB APPLICATIONS AND TECHNOLOGIES - CT0142
- https://www.evemilano.com/protocolli-http/

PEGASO
Università Telematica

Attenzione! Questo materiale didattico è per uso personale dello studente ed è coperto da copyright. Ne è severamente vietata la riproduzione o il riutilizzo anche parziale, ai sensi e per gli effetti della legge sul diritto d'autore (L. 22.04.1941/n. 633).